
KAIF

Kindred Agent Identity Framework

A Non-Human Principal Authorization Protocol for Autonomous AI Agents

Document Status	DRAFT — v0.9.0
Classification	Technical Specification
Issuing Authority	Kindred Systems OS
Primary Author	Geoff — Kindred Systems
Date	May 2026
Standards Basis	RFC 8693, RFC 9635, SPIFFE/SPIRE, OAuth 2.1, OIDC
Target Audience	Security Architects · Platform Engineers · Standards Bodies

1. Abstract

The proliferation of autonomous AI agents operating across organisational boundaries introduces a class of authorisation problem that existing identity protocols were not designed to solve: how does a non-human principal — an agent — acquire scoped, auditable, and revocable authority that is cryptographically traceable to a specific human decision?

This specification defines the **Kindred Agent Identity Framework (KAIF)**, a composable protocol stack for non-human principal authorisation. KAIF integrates SPIFFE/SPIRE workload attestation, RFC 8693 OAuth 2.0 Token Exchange, and a trust-score-gated issuance layer to produce agent credentials that are: (a) human-principal-traceable, (b) short-lived and scoped, (c) adaptively revocable without key rotation, and (d) fully auditable via a SHA-256 hash-chained event log.

Core Proposition

KAIF does not replace OAuth, SPIFFE, or Azure Managed Identity. It composes them into a coherent agent governance protocol that none of them provides individually — specifically addressing the autonomous AI agent authorisation gap that will affect every enterprise deploying AI systems in the next 18 months.

2. Problem Statement

2.1 The Authorisation Gap

Current enterprise identity infrastructure was designed for two principal types: human users and static service accounts. AI agents introduce a third category with fundamentally different properties:

Property	Human User	Service Account	AI Agent
Identity lifespan	Years	Months–years	Minutes–hours
Authority source	HR / directory	Admin provisioned	Human delegation
Behavioural variance	Low	None	High — emergent
Delegation depth	Single hop	None	Multi-hop, dynamic
Trust basis	Authentication	Secret possession	Attestation + behaviour
Revocation speed	Seconds	Minutes (rotation)	Must be sub-second
Audit requirement	Standard	Standard	Continuous, cryptographic

2.2 Why Existing Approaches Fall Short

- **OAuth 2.0 client credentials** — agents authenticate with a static client secret. No workload attestation, no principal chain, no trust scoring. The secret is the identity.
- **Azure Managed Identity** — eliminates secrets for Azure workloads but provides no inter-agent delegation chain, no trust score gate, and no cross-cloud portability.
- **SPIFFE/SPIRE alone** — solves workload attestation excellently but provides no delegation semantics, no human principal tracing, and no AI-specific trust model.
- **HashiCorp Vault** — strong secret management but no agent-specific authority chain. Agents access secrets, not authority. No behavioural trust layer.
- **MCP OAuth 2.1 (2025 spec)** — the closest existing approach. Covers agent-to-service OAuth flows but stops short of human principal tracing, workload attestation, and adaptive revocation.

The Gap in One Sentence

No existing production standard provides: workload-attested agent identity + human-principal-traceable delegation + trust-score-adaptive revocation + cryptographic audit — as a unified, composable protocol.

3. Standards Basis & Alignment

3.1 Foundational Standards

Standard	Role in KAIF	Status
RFC 8693 — OAuth 2.0 Token Exchange	Human-to-agent delegation via actor/may_act claims	Ratified 2020
RFC 9635 — G NAP	Next-generation grant negotiation for agent flows	Ratified 2024
RFC 9068 — JWT Profile for OAuth 2.0	Canonical KAIF token format with custom agent claims	Ratified 2021
RFC 8705 — mTLS for OAuth	Transport binding — token bound to agent TLS certificate	Ratified 2020
RFC 7519 — JSON Web Token	Token serialisation format	Ratified 2015
SPIFFE SVID Specification	Agent workload identity document (X.509 or JWT-SVID)	CNCF Ratified
SPIRE Runtime Attestation	Node and workload attestation plugins	CNCF Ratified
OpenID Connect Core 1.0	Human IdP integration (Azure Entra, Google, Okta)	Final

3.2 RFC 8693 Token Exchange — Key Constructs

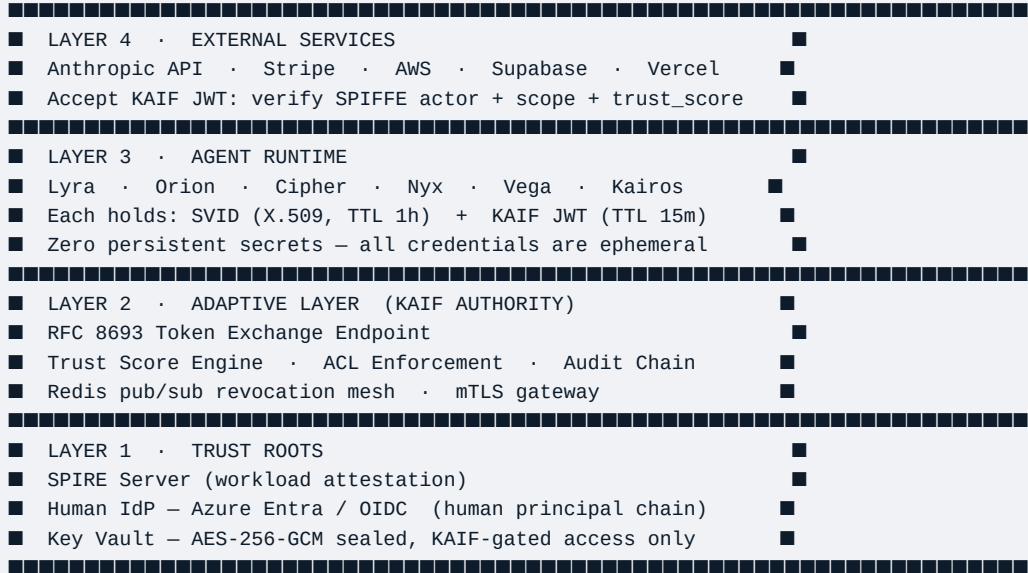
RFC 8693 defines a token exchange grant type that allows one principal to request a token that acts on behalf of another. KAIF uses the *delegation* pattern exclusively — the agent does not impersonate the human, it acts under the human's grant with a distinct identity:

```
POST /oauth/token
grant_type=urn:ietf:params:oauth:grant-type:token-exchange
&subject_token=<human_access_token>
&subject_token_type=urn:ietf:params:oauth:token-type:access_token
&requested_token_type=urn:ietf:params:oauth:token-type:access_token
&scope=vault:read:anthropic_key vault:read:stripe_key invoke:completion
&actor_token=<agent_svid_jwt>
&actor_token_type=urn:ietf:params:oauth:token-type:jwt

// Response token contains:
// sub - human principal (geoff@kindred.systems)
// actor - agent SPIFFE ID (spiffe://kindred.systems/.../lyra)
// scope - granted subset only
// kaif - trust_score, delegation_depth, rollback_window
```

The resulting agent token is cryptographically bound to both the human principal (via **sub** claim) and the agent workload (via **actor** claim containing the SPIFFE ID). Neither credential alone is sufficient for authorisation.

4.1 Four-Layer Stack



4.2 KAIF JWT — Token Schema

Every KAIF access token is a signed JWT (RS256) conforming to RFC 9068 with KAIF-specific extension claims in the **kaif** namespace:

```
{
  "iss": "https://auth.kindred.systems",
  "sub": "human:geoff@kindred.systems",           // human principal – never the agent
  "aud": "https://api.anthropic.com",             // target service
  "iat": 1748736000,
  "exp": 1748736900,                             // 15-minute TTL
  "jti": "f47ac10b-58cc-4372-a567-0e02b2c3d479", // revocation handle
  "scope": "vault:read:anthropic_key invoke:completion",

  "actor": {
    "sub": "spiffe://kindred.systems/ns/adaptive-layer/agent/lyra",
    "svid_thumbprint": "sha256:a3f4c8d2..."     // RFC 8705 mTLS binding
  },
  "may_act": {
    "sub": "spiffe://kindred.systems/ns/adaptive-layer/agent/lyra"
  },

  "kaif": {
    "trust_score": 0.94,                          // continuous behavioural score
    "trust_tier": "VERIFIED",
    "delegation_depth": 1,                         // hops from human principal
    "delegation_id": "dlg:7f3a8c...",             // audit trail anchor
    "rollback_window": "PT10M",                   // ISO 8601 duration
    "principal_chain": ["geoff@kindred.systems"]
  }
}
```

5. Trust Hierarchy Model

5.1 Trust Tiers

Tier	Score	Token TTL	Max Depth	Permitted Scope
PROVISIONAL	0.00–0.49	5 min	0 (self only)	Read-only, sandboxed operations
STANDARD	0.50–0.69	10 min	1	Read + limited write
VERIFIED	0.70–0.89	15 min	2	Full operational scope
TRUSTED	0.90–1.00	15 min	3	Full scope + sub-delegation

5.2 Trust Score Composition

The trust score is computed continuously by the Adaptive Layer from four weighted signal classes. Scores update per-invocation and feed directly into token issuance decisions:

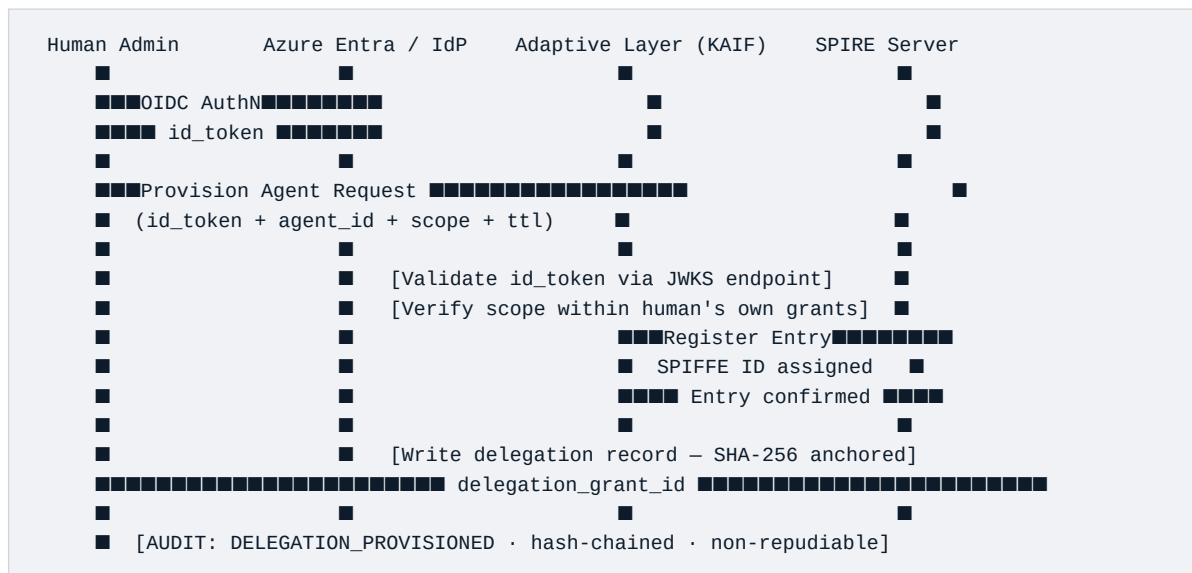
Signal Class	Weight	Source	Frequency
Behavioural consistency	35%	Deviation from declared task envelope — Adaptive Layer	Per-invocation
Audit chain integrity	30%	SHA-256 chain verification — no gaps or mutations	Continuous
Credential hygiene	20%	SVID rotation compliance, token reuse detection	Per-rotation
Peer attestation	15%	Signals from co-operating agents (consensus-weighted)	Per-interaction

5.3 Adaptive Revocation — Three Modes

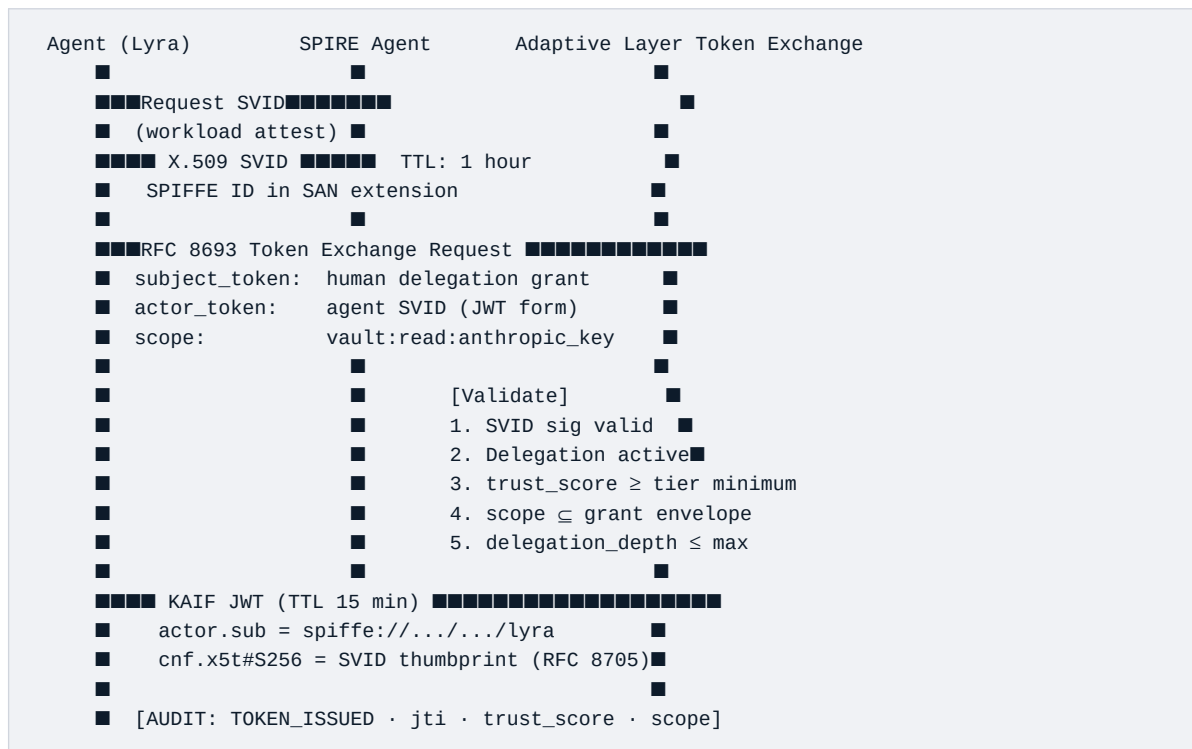
- **Threshold Revocation** — Trust score drops below 0.5. Adaptive Layer immediately removes the agent's SPIRE entry. SVID issuance halts. All inflight tokens added to JTI denylist. Propagation via Redis pub/sub: <5 seconds.
- **Scope Reduction** — Score between 0.5 and 0.7 triggers scope contraction without full revocation. New tokens issued with reduced scope. Existing tokens flagged for introspection on every use.
- **Human-Triggered Revocation** — A human principal with OWNER role invalidates all tokens derived from their delegation grant. Propagates atomically to all agents in the delegation chain via Redis pub/sub.

6. Protocol Flows

6.1 Human Principal Provisioning



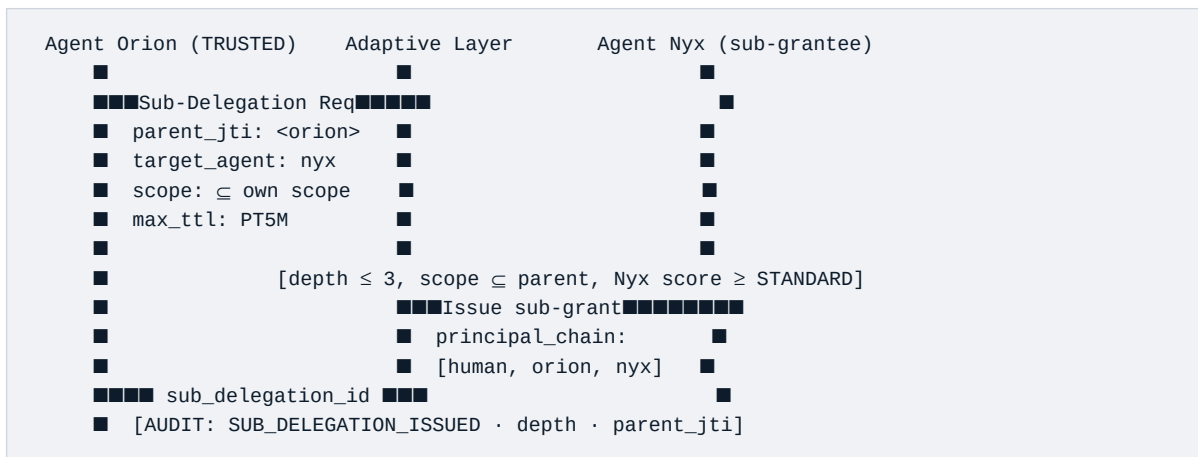
6.2 Agent Authentication & Token Acquisition



6.3 Agent-to-External-Service Call



6.4 Sub-Delegation (TRUSTED Tier Only)



7. Threat Model (STRIDE)

Threat	Attack Vector	KAIF Mitigation	Residual Risk
Spoofing	Agent forges identity	SPIRE workload attestation — cryptographic, not claim-based. SVID cannot be forged without SPIRE root compromise.	LOW
Tampering	Token manipulation post-issuance	JWT signature (RS256) + RFC 8705 certificate thumbprint binding. Tampered token fails both checks.	NEGLIGIBLE
Repudiation	Agent denies performed action	SHA-256 hash-chained audit log. Every issuance and access is anchor-linked. Cryptographically non-repudiable.	NEGLIGIBLE
Information Disclosure	Secret exfiltration via agent	Agents receive scoped tokens, not raw secrets. Secrets sealed AES-256-GCM. mTLS encrypts all transport.	LOW
Denial of Service	Token flood / revocation storm	Redis rate limiting on Token Exchange. Revocation via SPIRE entry deletion is O(1), not O(n) iteration.	MEDIUM
Elevation of Privilege	Agent acquires excess scope	Scope cannot exceed parent grant. Depth hard-limited. Trust score gates access tier at issuance time.	LOW

7.1 AI-Specific Attack Surfaces

- **Prompt injection** → **credential abuse** — adversarial input causes agent to request out-of-scope tokens. Mitigated by: scope is declared at provisioning time, not runtime. Adaptive Layer ACL blocks out-of-envelope requests. Behavioural score penalises anomalous request patterns immediately.
- **Agent impersonation** — one agent presents as another. Mitigated by: SPIFFE ID is embedded in the SVID's Subject Alternative Name (cryptographic, not a claim). RFC 8705 mTLS binding ensures only the agent holding the SVID private key can present the corresponding bearer token.
- **Token leakage via agent memory** — long-lived tokens extracted from a compromised agent process. Mitigated by: 15-minute TTL limits blast radius. JTI denylist enables immediate invalidation. RFC 8705 binding makes a stolen bearer token useless without the SVID private key.
- **Delegation chain pollution** — compromised STANDARD-tier agent attempts to issue sub-grants. Mitigated by: only TRUSTED-tier (score ≥ 0.9) agents may sub-delegate. Trust score degrades rapidly for compromised agents, triggering revocation before meaningful damage occurs.

8. Platform Interoperability

Platform	Integration Mechanism	Effort
Microsoft Azure	Azure Entra ID as human IdP (OIDC). SPIRE overlaid on AKS node attestation. Federated Credential issued to KAIF Token Exchange endpoint. KAIF JWT accepted by Azure services via Workload Identity Federation.	Medium
AWS	IAM + STS AssumeRoleWithWebIdentity. KAIF SVID JWT presented to STS. Role mapped to trust tier. AWS resources accessed via short-lived STS credentials — KAIF manages the outer delegation chain.	Medium
Google Cloud	Workload Identity Federation. KAIF JWT presented as external identity to GCP Workload Identity pool. STS exchanges for GCP access token. Fully composable.	Low–Medium
HashiCorp Vault	JWT auth method + PKI secrets engine. KAIF JWT used as Vault auth token. Vault policies map to KAIF trust tiers. Vault PKI issues short-lived certs to agents.	Low
MCP (Anthropic 2025)	KAIF JWT serves directly as the OAuth 2.1 bearer token for MCP tool calls. actor claim satisfies MCP's client identity requirement with no additional bridging.	Very Low
Kubernetes	SPIRE Kubernetes workload attestor uses pod identity for SVID issuance. Native integration — no modification to cluster required.	Low

9. Compliance Posture

Framework	Relevant Controls	KAIF Coverage
SOC 2 Type II	CC6.1 Logical access · CC6.6 External access · CC7.2 Monitoring	Full — cryptographic audit chain satisfies evidence requirements. Automated revocation satisfies access removal controls.
ISO 27001	A.9 Access control · A.12.4 Logging · A.14 Secure development	Full — non-repudiable audit log (A.12.4), least-privilege scoped tokens (A.9), SPIFFE-attested identity (A.9.4).
NIST SP 800-207	Zero Trust Architecture — all seven tenets	Full — explicit per-request verification, no implicit trust, microsegmentation via scope, continuous monitoring via trust score.
GDPR / UK GDPR	Art. 25 Data protection by design · Art. 32 Security of processing	Full — agents never receive credential material directly. Audit log supports Art. 30 records of processing activities.
FedRAMP	AC-2 Account Mgmt · AU-2 Audit Events · IA-3 Device Identification	Partial — architecture is FedRAMP-compatible. Certification requires US-based SPIRE deployment and FedRAMP-authorized IdP.

10. Comparison Matrix

Capability	KAIF	Azure MI	SPIFFE/SPIRE	HashiCorp Vault	MCP OAuth 2.1
Workload attestation	✓	Azure only	✓	—	—
Human principal tracing	✓	—	—	—	—
RFC 8693 delegation	✓	—	—	—	—
Trust-score-gated issuance	✓	—	—	—	—
Adaptive revocation (<5s)	✓	—	—	—	—
Sub-delegation with depth limits	✓	—	—	—	—
SHA-256 audit chain	✓	—	—	Partial	—
mTLS token binding (RFC 8705)	✓	Partial	✓	—	—
Cross-cloud portability	✓	—	✓	✓	✓
AI-agent behavioural model	✓	—	—	—	—
Secret injection — no exposure	✓	✓	—	✓	—
Kubernetes native	✓	AKS only	✓	✓	—

✓ = Supported · — = Not supported · Partial = Platform-scoped

11. Adaptive Layer Integration

Adaptive Layer Component	KAIF Role
Redis pub/sub mesh	Token revocation propagation (<5s). vault.secret.request channel. Agent identity events broadcast on dedicated KAIF topic.
SHA-256 audit chain	Canonical log for all KAIF events — issuance, revocation, delegation, access denial. Every entry hash-linked to the previous.
Trust score engine	Feeds directly into token issuance gate and scope assignment. The core policy decision point — no token issued without a score check.
Rollback window	Maps to KAIF delegation TTL. A rollback revokes all tokens issued within the window for that agent, atomically.
Agent registry (Lyra, Orion, etc.)	Each named agent maps 1:1 to a SPIFFE ID and ACL entry. Agent name is the human-readable alias for the SPIFFE principal.
Key Vault	AES-256-GCM sealed at rest. KAIF tokens authorise access. Raw secrets never transmitted — agents receive authority, not keys.

11.1 Agent ACL Configuration

```
# Adaptive Layer — Agent Authorization Config (YAML)
agents:
  lyra:
    spiffe_id: spiffe://kindred.systems/ns/adaptive-layer/agent/lyra
    trust_tier_minimum: STANDARD
    permitted_scopes:
      - vault:read:anthropic_key
      - invoke:completion
    may_sub_delegate: false
    delegation_ttl: PT15M
    human_principal_required: true

  orion:
    spiffe_id: spiffe://kindred.systems/ns/adaptive-layer/agent/orion
    trust_tier_minimum: VERIFIED
    permitted_scopes:
      - vault:read:*
      - invoke:*
      - agent:delegate
    may_sub_delegate: true
    max_delegation_depth: 2
    delegation_ttl: PT15M
    human_principal_required: true
```

12. Implementation Roadmap

Phase	Deliverable	Effort	Dependencies
P0 — Foundation	SPIRE server · SPIFFE ID schema · SVID issuance per agent	1–2 weeks	Kubernetes / Docker
P0 — Foundation	RFC 8693 Token Exchange Endpoint (Node/Fastify)	1 week	Adaptive Layer API
P0 — Foundation	KAIF JWT minting — trust_score + actor + kaif claims	3 days	Trust score engine (exists)
P1 — Integration	Vault microservice — AES-256-GCM + KAIF-gated access	1 week	Redis (exists) + P0
P1 — Integration	Azure Entra as human IdP — OIDC integration	3–5 days	Azure tenant
P1 — Integration	mTLS gateway — SVID-based client authentication	1 week	SPIRE P0
P2 — Hardening	RFC 8705 certificate binding enforcement	3 days	P0 + P1
P2 — Hardening	Adaptive revocation via Redis pub/sub JTI denylist	3 days	Redis pub/sub (exists)
P2 — Hardening	KAIF admin console — delegation provisioning UI	1 week	P0 + P1
P3 — Enterprise	WebAuthn passkey for human admin unlock	1 week	P1 IdP
P3 — Enterprise	GNAP (RFC 9635) — async human approval flows	2–3 weeks	P0 + P1
P3 — Enterprise	Cross-cloud federation — AWS STS + GCP WIF	2 weeks	P1

13. Conclusion

The autonomous agent authorisation problem is not solved by hardening existing OAuth or secrets management systems. It requires a purpose-built delegation protocol that treats agent behaviour as a continuous variable — not a binary authentication event — and that provides a cryptographic chain of custody from every agent action back to a named human decision.

KAIF provides this by composing three mature foundations — SPIFFE/SPIRE workload attestation, RFC 8693 token exchange, and the Adaptive Layer's behavioural trust engine — into a protocol where agent authority is continuously earned, cryptographically bounded, and human-traceable.

The result is a system where a compromised agent cannot hold authority for longer than its trust score permits; where every access event is non-repudially recorded; where secrets are never transported — only authority to access them — and where the human principal's intent is embedded in every token the agent holds.

Market Position

KAIF occupies the gap between infrastructure identity (SPIFFE, Azure MI) and application security (OAuth, HashiCorp Vault). It is the governance layer that transforms a fleet of capable agents into a trustworthy agentic system. That is the problem every enterprise deploying AI will face — and currently, nobody ships a coherent solution for it.

14. References

Identifier	Title	Source
RFC 8693	OAuth 2.0 Token Exchange	IETF, 2020
RFC 9635	Grant Negotiation and Authorization Protocol (GNAP)	IETF, 2024
RFC 9068	JWT Profile for OAuth 2.0 Access Tokens	IETF, 2021
RFC 8705	OAuth 2.0 Mutual-TLS Client Authentication	IETF, 2020
RFC 7519	JSON Web Token (JWT)	IETF, 2015
SPIFFE	Secure Production Identity Framework for Everyone	CNCF
SPIRE	SPIFFE Runtime Environment	CNCF, spiffe.io
NIST 800-207	Zero Trust Architecture	NIST, 2020
OpenID Connect	OpenID Connect Core 1.0	OpenID Foundation, 2014
OAuth 2.1	The OAuth 2.1 Authorization Framework (draft)	IETF OAuth WG, 2024